



Module 21 Day 1: Interpreting IR Plans

Solutions:

- To what type of industry/institution did each organization belong?
 - Homeland Security: National Government
 - Carnegie Mellon: University (Private)
 - The State of Oregon: State Government
 - Virginia Tech: University (Public)
- Compare the table of contents for each document. Which sections do most documents have in common?

Common themes and sections include:

 - Introduction, purpose, and scope
 - Authority, training, and definitions
 - Preparation, detection, and containment
- While there are several common sections, these plans are quite distinct, each with unique topics to fit their individual needs.

Less common themes include:

 - Executive summary, document structure, and audience
 - Insider threats, communications, and private sector
 - Access control, forensics, and escalation
- What was interesting or potentially useful and why?

Answers may vary:

 - The fact that all four plans are so different could be enlightening.
 - Many of the plans talk about the CIA triad.
- National Government (Homeland Security)
 - This document is meant to be a framework, not a tactical or operational plan.
 - Many departments follow this plan including The DOJ, FBI, NCIJTF, and DHS
 - This plan has a Guiding Principles section that affected parties should follow.
 - This plan also distinguishes between "Cyber Incident" and "Significant Cyber Incident"

- University (Carnegie Mellon)
 - Carnegie Mellon has an entire "office" responsible for creating and maintaining documents.
 - It describes an "Event" as any exception outside normal operations.
 - It mentions both PII and PHI.
 - Carnegie Mellon calls its analysts Incident Response Handlers.
- State Government (Oregon)
 - This plan seems less official than the Nation Plan.
 - There is a CISO position for the state of Oregon (and other states), responsible for state-wide information security.
 - Oregon State also has a position called Incident Commander that seems to resemble a SOC analyst role.
 - Oregon keeps a full-time Enterprise Security Office (ESO) on staff whose primary focus is analysis, but not detection, of incidents.
- University (Virginia Tech)
 - VT follows a checklist for incident handling.
 - It addresses some very specific attacks, such as botnet DDoS attacks and ransom attacks.
 - It includes a chart of changes that occurred to the document.